RBC CAPITAL MARKETS · DIGITAL ASSET TECHNOLOGY · ANALYSIS

HSM vs MPC for institutional custody and signing

JP Creedon · Head of Digital Asset Technology, RBC Capital Markets · October 30, 2026 · For senior technology and risk leaders

BOTTOM LINE

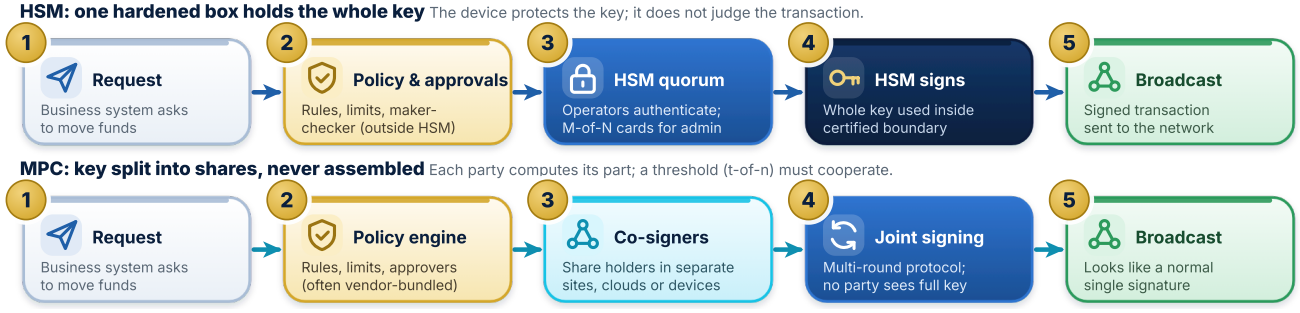
- **Different strengths, not a winner.** HSMs give a certified hardware boundary that supervisors and auditors know well; MPC removes the single whole key and makes multi-chain, multi-site signing and key-share refresh easier.
- **Both have real failure history.** Published HSM firmware flaws (Ledger Donjon, 2019) and MPC protocol and implementation flaws (BitForge and TSSHOCK, 2023) show that assurance depends on the implementation and its patching, not the label[3,4,5].
- **Neither stops a signer being tricked.** In the Binance incident, no key leaked; the signing system signed the attacker's requests[8,9]. The policy and intent-verification layer decides losses.
- **Recommendation:** Core-Edge. Cold custody (Fort Knox) on HSM or hybrid MPC-in-HSM; Lines of Business run hot and warm wallets on MPC; one shared policy and intent-verification standard across both.

One-glance comparison

Dimension	HSM (hardware security module)	MPC (multi-party computation / threshold signing)	Edge
Security model	Single tamper-resistant hardware boundary protects the key; security rests on the device, its firmware and who can operate it	Key split into shares on separate parties; a threshold (t-of-n) must cooperate; no single device or person can sign alone	Even
Key existence	Whole key exists, inside the device and in wrapped backups or clones	Full key never assembled when created by distributed key generation (an imported key existed whole once)	MPC
Certifications	Devices validated under FIPS 140-3 (commonly Level 3) and Common Criteria; FIPS 140-2 certificates moved to NIST's Historical list on 21 Sep 2026, still usable in existing systems[1]	No certification covers the threshold protocol itself; assurance comes from peer-reviewed protocols, audits, vendor SOC 2 / ISO 27001 and any validated hardware underneath. NIST's threshold-schemes call (NIST IR 8214C, Jan 2026) is under way; no standard yet[2]	HSM
Regulatory acceptance	Long-established control in bank payments and PKI; well understood by auditors and supervisors	Widely used by crypto custodians; expect to explain the model and evidence each share holder's controls	HSM
Multi-chain & curves	Depends on firmware: secp256k1 and Ed25519 support varies by vendor and model; new schemes wait for vendor updates or custom code	Software-defined; threshold ECDSA and EdDSA common; new chains added in software, but each new scheme needs its own vetted protocol	MPC
Latency & throughput	Signing happens in one device; low latency; scale by adding devices	Several network rounds between parties; latency grows with distance; plan capacity for hot-wallet peaks	HSM
Rotation & resharing	Rotating a blockchain key means a new address and moving funds	Shares can be refreshed or the quorum changed without changing the key or address	MPC
Recovery & DR	Mature: encrypted backups, cloning to standby HSMs, M-of-N key ceremonies	Share backups and vendor recovery tooling; must prove recovery works without the vendor	HSM
Policy & approvals	Device enforces who may use a key, not what a transaction means; policy lives outside	Platforms bundle policy engines and approval workflows; co-signers can check rules before taking part	MPC
Vendor lock-in	Standard interfaces (PKCS#11), but keys rarely exportable across vendors	Proprietary protocols; shares not portable; exit usually means moving funds to new addresses	Even
Cost & operations	Hardware, data-centre space, ceremonies, specialist staff	Licence or subscription; distributed nodes to run and patch; less physical estate	Even
Auditability	Mature device logs and certified boundary	Per-party and platform logs; on-chain the signature hides which parties approved	HSM

"Edge" is our editorial judgement of which model is stronger on that dimension for a bank, not a formal rating. No cost or performance figures are quoted because they vary by vendor and deployment.

How each model signs



Signing flows. In both models the policy step (gold) sits outside the key protection. That is where the Binance attack succeeded.

THREATS, HYBRIDS AND RECOMMENDATION

Where each model fails, and how to combine them

Threat analysis

Threat	HSM	MPC	Published examples and notes
Physical	Tamper-response hardware; stealing or probing one device is hard	Attacker must compromise t parties in separate locations	Physical attacks are the least likely route for remote attackers such as those behind recent exchange thefts
Insider	M-of-N quorum for admin; risk if one person holds both admin and operator roles	No single admin holds the key; but the platform operator ships the software running on every node	Separate roles; vendor-insider risk applies to both firmware (HSM) and node software (MPC)
Supply chain	Firmware integrity is critical	Open-source and vendor libraries; some threshold libraries are no longer maintained[4]	**HSM, 2019:** Ledger Donjon found 14 flaws in one vendor's HSM, including unauthenticated remote code execution and a firmware-signature bypass allowing a persistent backdoor; fixed by the vendor[3]
Side-channel	Certified designs are tested against leakage	MPC shares often run in secure enclaves, which have had side-channel breaks	**Enclave, 2020:** SGAxe extracted Intel SGX attestation keys via a cache side channel, after host compromise[7]
Implementation bugs	Memory-safety and parsing bugs in device firmware[3]	Young protocols; missing zero-knowledge proofs or mishandled aborts can leak shares	**BitForge (Fireblocks, Aug 2023):** CVE-2023-33241 (GG18/GG20) key extraction in 16 to 1 billion signatures depending on implementation; CVE-2023-33242 (Lindell17) after about 200 signature requests; affected vendors incl. Coinbase WaaS, Zengo, Binance, since patched[4]. **TSSHOCK (Verichains, Black Hat, Aug 2023):** one malicious party extracts the key after 1-2 signatures in vulnerable GG18/GG20/CGGMP21 implementations[5]. **Alpha-Rays (2021)**: earlier GG18/GG20 key-extraction attacks[6]
Tricked signer	Signs whatever authorised software asks	Co-signers sign whatever passes their rules	**Binance, Oct 2026:** no evidence of key leak; signing pipeline produced attacker signatures across 10 chains[8,9]

Hybrid patterns

MPC with shares inside HSMs or enclaves

- No whole key anywhere, and each share sits behind a hardware boundary.
- Mix share hosts (HSM, enclave, offline device) so one class of bug cannot reach a threshold of shares.
- Enclaves add speed but carry side-channel history[7]; prefer HSMs for cold.

Cold HSM, hot and warm MPC

- Treasury and cold reserves on HSMs: offline, ceremony-based, slow by design.
- Hot and warm wallets on MPC: multi-chain, fast, share refresh, built-in policy.
- Hot wallets hold a working float, refilled from warm or cold under separate approval.

THE BINANCE LESSON APPLIES TO BOTH

Binance reported no evidence of a private-key leak; analysts conclude the attacker made the hot-wallet signing system sign transactions of its choosing[8,9]. An HSM would have signed them; an MPC quorum would have co-signed them. Key protection decides whether a key can be **stolen**; the policy and intent-verification layer decides what gets **signed**. That layer needs a signer that builds and parses the transaction itself, an independent co-signer that checks it against the business intent, value and velocity limits, and a kill switch.

Recommendation: Core-Edge

- **Core: cold custody (Fort Knox).** HSMs validated to FIPS 140-3 (Level 3) or hybrid MPC with shares inside HSMs across sites; offline signing ceremonies; recovery tested without any single vendor.
- **Edge: Lines of Business.** Hot and warm wallets on an MPC platform with per-business vaults and policies; small balances refilled from warm or cold; independent co-signer run by a separate team.
- **Across both:** one policy and intent-verification standard and Global Risk Management Watchtower gates; diversity of share hosts or vendors; due diligence that MPC libraries include the BitForge and TSSHOCK fixes.
- **Next steps:** confirm the FIPS 140-3 status of the hardware protecting Fort Knox keys after the FIPS 140-2 transition; run a vendor bake-off on the comparison dimensions above; tabletop a Binance-style tricked-signer scenario on both tiers.

Sources: [1] NIST CMVP, csrc.nist.gov/projects/fips-140-3-transition-effort · [2] NIST Threshold Cryptography, csrc.nist.gov/projects/threshold-cryptography · [3] Ledger Donjon, "Everybody be Cool, This is a Robbery!" (Black Hat 2019), ledger.com/blog/blackhat2019-presentation · [4] Fireblocks, BitForge, fireblocks.com/blog/bitforge-... and CVE technical reports · [5] Verichains, TSSHOCK, verichains.io/tsshock · [6] Tymokhanov & Shlomovits, Alpha-Rays, eprint.iacr.org/2021/1621 · [7] SGAxe, sgaxe.com · [8] Binance Security Incident Update, 30 Oct 2026 · [9] TRM Labs, Binance incident analysis, 30 Oct 2026 (links in the Binance Incident Update). Comparisons are our analysis, not vendor claims; not an assessment of any RBC system.